

The \$PENIS Endowment: Security Review Summary

An AI-assisted adversarial security review of the endowment contract, automation and website, in three rounds plus a final focused check and a full launch rehearsal on a fork of Solana mainnet. Every finding was resolved or is a documented design choice. In no round did the review find any way for anyone to take funds.

Scope

- The endowment contract: a shared, multi-endowment Solana program (Anchor), open source at <https://github.com/The-Endowment/endowment>
 - Reviewed commit: `3bfce2c4aa4e8e560a94c749ebf273c3b53a7d58`
 - The automation (sweeps, daily count, refresh checks, buys) and the website opt-in and Leave flows
-

Method

- **Scoped reviewers.** Independent reviewers, one per attack surface: access control, token handling, pricing, counting, governance, economic attacks, and the automation and website.
 - **Adversarial verification.** A separate reviewer tried to refute every finding. Anything rated high had to be proven with a working exploit test against the real program and real pool data.
 - **Regression checks.** Each round re-checked every earlier finding against the code, not against the fix notes.
 - **Completeness critic.** A final reviewer each round looked for anything the others missed.
 - **Live rehearsal.** The whole launch was run on a fork of mainnet with the real PUMP and \$PENIS tokens and the real Raydium pool.
-

Results

- **Round 1, full review.** The first complete contract, automation and website. Every finding was addressed in a redesign.

- **Round 2, full review.** The shared multi-endowment contract, plus a re-check of every round-1 finding. 62 resolved, 12 accepted by design, 3 completed at launch.
 - **Round 3, targeted review.** The new counting and pricing mechanisms. 21 resolved, 1 accepted by design.
 - **Final check.** Every round-3 change, re-verified. All resolved.
 - **Launch rehearsal.** 7 of 7 steps passed: opting in, dividend sweeps, the daily count, the 30% switch, real buys against the pool, pausing and settings changes.
 - **Tests.** 152 automated tests, including one for every exploit found during the review.
-

What the contract guarantees

- **\$PENIS never leaves.** No function can move \$PENIS out of the vault, or withdraw locked liquidity.
 - **Landlords keep what they hold.** The endowment can only take new PUMP above the balance a landlord held when joining, and nothing else in the wallet.
 - **Leaving never depends on us.** Revoking works from any wallet, without the website.
 - **Changes are slow and public.** Settings changes wait 72 hours and stay within hard limits written into the code.
 - **The pause is limited.** It lasts at most 7 days, can't be renewed back to back, and can't move funds.
 - **Safe tokens only.** Endowments can only be created for coins nobody can mint more of, freeze, or take back from wallets.
 - **Fair prices.** Buys are priced against the pool's own recent average and sized to its depth, so a trade placed just before a buy can't push the price against the endowment.
-

Design choices

- **The refresher.** An automation key checks landlords before each daily count. It can't move funds, its role is shown publicly for every endowment, and it can resign at any time.
- **Counting is public.** Each landlord's counted \$PENIS is on-chain and shown on the website, so any attempt to game the count is costly and visible.
- **Outside token settings.** PUMP and \$PENIS each have a setting controlled by a third party. If either changes, the endowment pauses buying and sweeping on its own, and nothing is lost.

The deployed code

The deployed program will be a verifiable build of the reviewed commit, so anyone can confirm that what is running matches what was reviewed. Once the founders' test is complete, the upgrade key is destroyed and the code can never change.

This review was carried out with AI-assisted adversarial methods. It is a summary for landlords and the public. Not financial advice.